Step 10 — MFA Support: Lost Phone

Board task Activity 4 — MFA Support · Ticket IAM-0004 · Microsoft Entra ID

A step-by-step guide to run the MFA-support activity with the prepared PowerShell script, and to produce the ticket. Everything runs on the office Mac with your own phone. About 45 minutes.

Project	Healthcare IAM Operations Simulation — Horizon Valley Medical Center (HVMC)
Prepared By	Sabitha S Karanavar
Version	1.0 — November 3, 2026 (prepared; not yet run)
Folder	`Entra_Hands_On_IAM_Operations/step10_mfa_support/` (GitHub) — working copy in `~/Downloads/HVMC_IAM_Entra_Handson/step10_mfa_support/`
User in the scenario	Dr. Sarah Chen (HVMC-1001), Doctors — fictional
Cost	$0 — Entra ID Free; no Azure resources

1. The scenario

Dr. Sarah Chen calls the help desk: she lost her phone this morning and cannot approve Microsoft Authenticator sign-ins. Whoever finds the phone might try to use it. The help desk must (1) make sure the caller really is Sarah, (2) sign her out everywhere, (3) remove the lost phone's MFA method, and (4) let her register her new phone — then record it all in a ticket.

Help-desk step	Why	Security principle
Verify the caller's identity first	Attackers phone help desks pretending to be staff (the 2023 MGM Resorts attack began this way)	Identity proofing
Revoke all sign-in sessions	Signs out every device, including the lost phone	Containment
Remove only the MFA methods	Password, groups and apps stay; she can register again straight away	Least change
User registers the new phone herself	The help desk never handles her credentials	Separation of duties
Check the audit log	Proves who removed what and when, and that she re-registered	Accountability

2. The prepared files

File	What it does
`Invoke-HvmcMfaSupport.ps1`	The help-desk script. **-Action Status**: read-only before/after view (account, MFA methods, audit events). **-Action Reset**: dry run by default; with **-Apply -VerifiedBy "..."** it revokes sessions and removes the MFA methods. **-Action Verify**: six checks after re-registration. Uses the Step 8b HVMC.Lifecycle module.
`README.md`	The same steps as this guide, short form
`ticket/IAM-0004.json`	The ticket's fixed text: request, priority, people, resolution notes, lessons, figure captions. You add the opened/closed times
`ticket/build_ticket.py`	Builds `Ticket_IAM-0004_MFA_Support.pdf` in the Week 7 ticket format. Before the run it shows orange [placeholders]; after the run it fills them from the evidence files and your screenshots
`evidence/` (created by the script)	JSON of each run. Kept on the Mac only (git-ignored)

Safety rule in the script	Effect
Dry run unless `-Apply`	You always see the plan first
`-Apply` needs `-VerifiedBy`	The reset is refused unless you record how the caller was verified
Admin-role accounts refused	Admin MFA recovery uses the break-glass process (Step 7), not the help desk
Only MFA methods removed	Authenticator, phone, OATH and FIDO2 methods; the password and the password-reset email are kept
Masking	Phone numbers and directory IDs are never shown or saved

3. Before you start

You need	Notes
The office Mac with PowerShell (`pwsh`)	Already set up (PowerShell 7.6.9 and the Microsoft Graph modules)
Your phone with Microsoft Authenticator	Acts as Sarah's "old" and then "new" phone
Sarah's password	From the protected staff-password zip (CHG-109). Type it into the browser only — never into a file or a chat
Your HVMC admin account	For the PowerShell sign-in; approve with your own Authenticator
A folder for screenshots	`step10_mfa_support/ticket/screenshots/` — use the file names given in each step

> **First-time sign-in.** The script needs the permission *UserAuthenticationMethod.ReadWrite.All*, which the Azure CLI sign-in does not include, so a browser window opens once. If it shows a permissions (consent) screen for *Microsoft Graph Command Line Tools*, approve it as the administrator. This is expected.

4. Run it — step by step

Open Terminal and start PowerShell in the folder:

```
pwsh
cd ~/Downloads/HVMC_IAM_Entra_Handson/step10_mfa_support
```

Private browser Your phone **Step 0 — Set-up: give Sarah an MFA method (the "old phone")**

Open a **private** browser window → `https://mysignins.microsoft.com/security-info` → sign in as `sarah.chen@<tenant>` with her password → **Add sign-in method** → Microsoft Authenticator → follow the prompts with your phone. If a *Let's keep your account secure* screen appears first, follow it instead. Sign out and close the window.

✔ **You should see:** Sarah's account in your Authenticator app, and *Microsoft Authenticator* on her Security info page

PowerShell **Step 1 — Before state (read-only) — the ticket is opened**

A browser sign-in opens the first time: use your admin account. Write down the time; it is the ticket's *opened* time.

```
./Invoke-HvmcMfaSupport.ps1 -Action Status
```

✔ **You should see:** `Sarah Chen (HVMC-1001) sign-in enabled: True` and `Microsoft Authenticator device: …`, `MFA methods: 1`

📸 **Screenshot:** `01_status_before.png`

Paper / ticket **Step 2 — Verify the caller — the most important step**

In a real help desk: call back on the phone number HR has on file, or confirm with her manager (Department lead), and never accept details the caller could have looked up. For the lab, decide the method; you type it in Step 4.

PowerShell **Step 3 — Dry run**

```
./Invoke-HvmcMfaSupport.ps1 -Action Reset
```

✔ **You should see:** `DRY RUN Lost-device reset`: 1. revoke all sign-in sessions, 2. remove Microsoft Authenticator …; `DRY RUN - nothing was changed`

📸 **Screenshot:** `02_reset_dryrun.png`

PowerShell Step 4 — Reset after the identity check

```
./Invoke-HvmcMfaSupport.ps1 -Action Reset -Apply -VerifiedBy "Call-back to the phone number HR has on file"
```

✔ **You should see:** each step `ok`, then `MFA methods: 0` and `RESET DONE`
📸 **Screenshot:** `03_reset_apply.png`

Private browser Your phone Step 5 — Sarah registers the "new phone"

On your phone, delete the old HVMC Sarah entry in Authenticator (that phone is "lost"). Private browser → `https://mysignins.microsoft.com/security-info` → sign in as Sarah (password only; she has no MFA method now) → **Add sign-in method** → Microsoft Authenticator → scan the new QR code → approve the test notification.
✔ **You should see:** the new Microsoft Authenticator on her Security info page
📸 **Screenshot:** `04_reregister.png`

PowerShell Step 6 — Verify — the ticket can be closed

Audit events can take up to 15 minutes to appear. If a check says FAIL, wait and run it again. Write down the time; it is the *closed* time.

```
./Invoke-HvmcMfaSupport.ps1 -Action Verify
```

✔ **You should see:** `6/6 checks passed`
📸 **Screenshot:** `05_verify.png`

Private browser Step 7 — Audit log in the portal

`https://entra.microsoft.com` → Users → Sarah Chen → **Audit logs**. (Sign-in logs are in the portal too; on Free tier they are not available through the API.)
✔ **You should see:** *Admin deleted security info* and *User registered security info*
📸 **Screenshot:** `06_audit_portal.png`

PowerShell Step 8 — Build the ticket

Open `ticket/IAM-0004.json` and fill in `"opened"` and `"closed"` (for example `"2026-11-04 14:05 EST"`). Then leave PowerShell and build:

```
exit
python3 ticket/build_ticket.py
```

✔ **You should see:** `wrote …/Ticket_IAM-0004_MFA_Support.pdf (filled)` — open it and check there are no orange placeholders left

Then tell Claude: "*Step 10 is done*". Claude checks the evidence, adds Step 10 to the IAM hands-on report, and pushes the ticket and the report.

5. The ticket template (IAM-0004)

Section	Filled from
Header table: ticket ID, request type, priority, status, people, opened/closed	IAM-0004.json (status becomes *Resolved and closed* once Verify has run)
Request	IAM-0004.json
Identity verification: method and result	The `-VerifiedBy` text from the Reset run
Systems and account changes (before / after)	Status, Reset and Verify evidence: MFA methods, sessions revoked at hh:mm UTC, password and access unchanged
Actions taken	Each Reset step with its time and result
Verification, and the audit trail table	The six Verify checks and the audit events since the reset
Resolution notes and lessons learned	IAM-0004.json (edit if you want different wording)
Evidence figures 1–6	Your screenshots in `ticket/screenshots/`

Verify check	Passes when
identity verified before the reset	Reset was run with `-VerifiedBy`
old MFA methods removed at reset	Every removal step was ok and no MFA method was left
new MFA method registered after the reset	A method exists that was created after the reset time
audit: admin deleted security info	The audit log shows the admin removal
audit: user registered security info	The audit log shows Sarah's new registration
account still enabled	Sarah was never disabled (an MFA reset is not a leaver action)

6. If something goes wrong

Problem	What to do
The browser shows *Need admin approval* or a consent screen	Sign in with your admin account and approve; tick *Consent on behalf of your organization* if offered
`Forbidden` / `accessDenied` on methods	The session lacks the scope: run `Disconnect-MgGraph`, then the command again and sign in
`holds an admin role` error	Correct: the script never resets admin accounts. Use Sarah (HVMC-1001) or another staff user
A `remove … FAILED` line	Run the same Reset -Apply command again; the default method can only go once the others are gone
Verify shows FAIL for the audit checks	Audit events are delayed up to 15 minutes; run Verify again later
Sarah cannot sign in at Step 5	Check her password in the protected zip; the reset did not change it. Her account is still enabled

Problem	What to do
You want to start over	Remove Sarah's Authenticator on her Security info page, then begin again at Step 0

7. Words you will see

Word	Meaning
MFA method	A second proof of identity, here the Microsoft Authenticator app on a phone
Revoke sessions	Invalidates every refresh token, so all devices must sign in again
Security info page	`mysignins.microsoft.com/security-info`: where a user adds or removes their own sign-in methods
Audit log	Entra ID's record of every change: who did what, to whom, and when
Security defaults	Microsoft's free baseline that requires MFA registration and MFA for admins and risky sign-ins